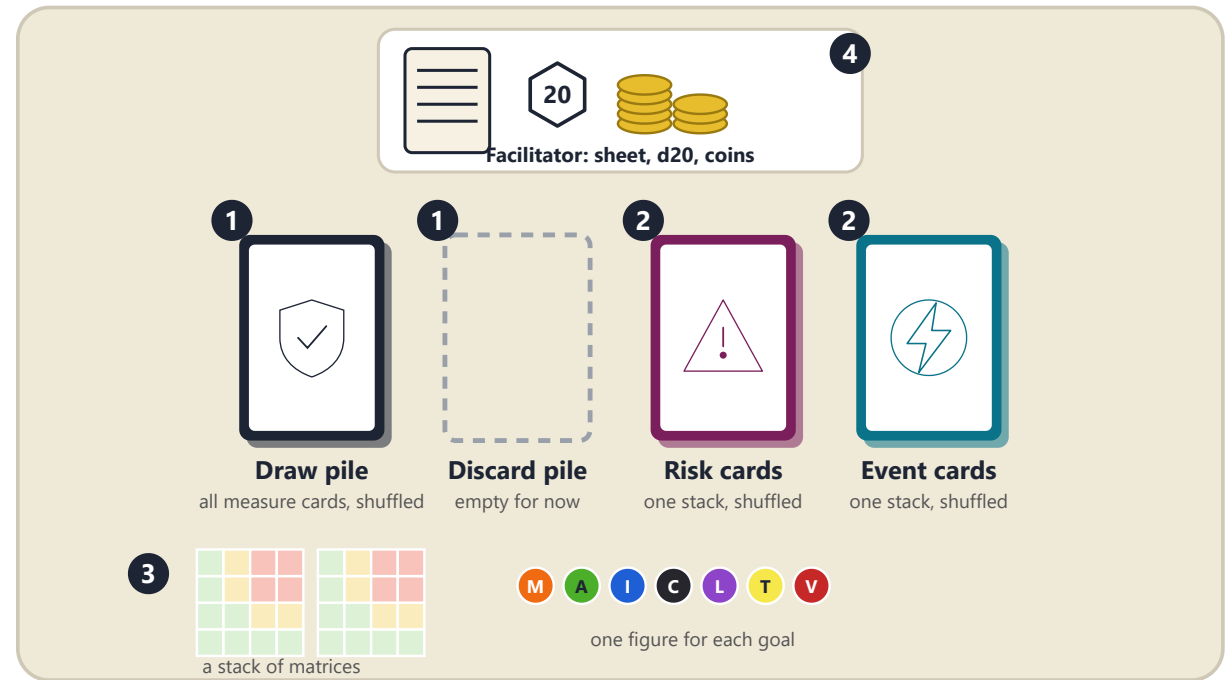


Set up the table: the middle

1. Shuffle **all measure cards** (grey, blue and yellow together) and put them in the middle: the **draw pile**. Leave room next to it for the **discard pile**.
2. Shuffle the **risk cards** into one stack and the **event cards** into another. Put both next to the draw pile.
3. Put a stack of **matrices** and the **figures** (one colour for each goal) where every team can reach them.
4. Keep the **facilitator sheet**, a **d20** and the **coins** at hand.



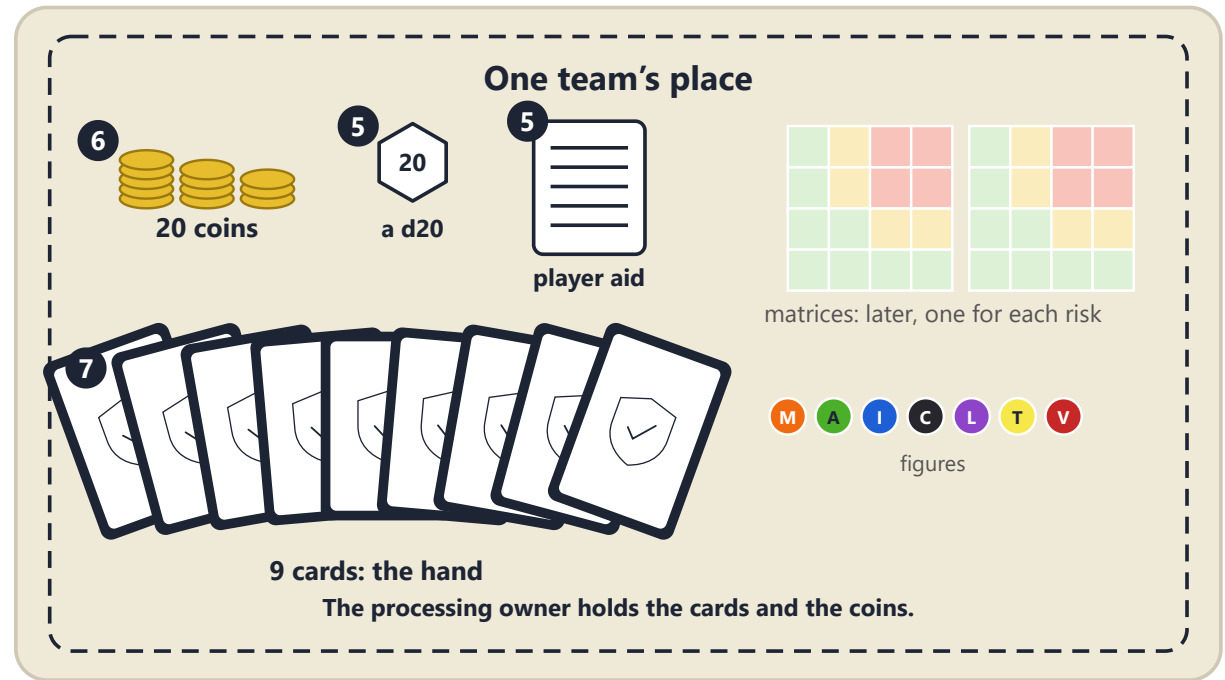
For today's pretend play stack the draw pile so the first six cards are, from the top: 1. Answer, don't keep, 2. Only your own patch, 3. Somebody reads the log, 4. Separate drawers, 5. Who covers on Friday?, 6. Names stay in the vault.

"Before we start, we set up the table together. Follow the numbers on the picture." Share your screen and do it with your own cards if you have them.

Set up the table: each team

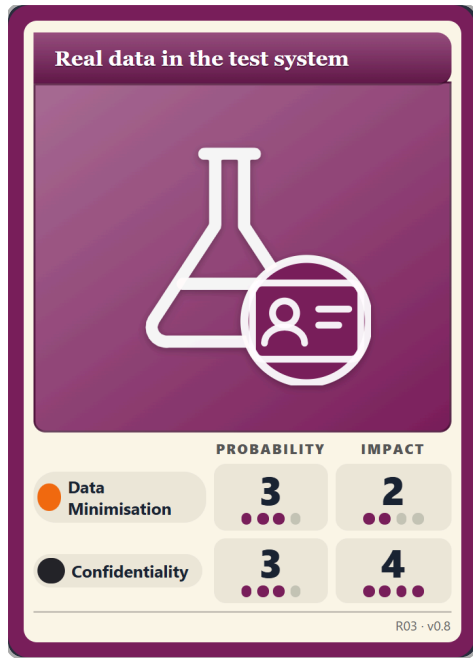
5. Give each team a **player aid** and a **d20**.
6. Give each team its **starting coins**: 20.
7. Deal each team **9 cards** from the draw pile.
8. Each team picks a **processing owner**: they hold the cards and the coins.

For today's pretend play the two hands are fixed: you see each hand on the page of its first turn. Risk cards in order: Real data in the test system, then Staff snoop in records. Event cards in order: A coupon, with a smile, Turns out it was a lot worse, Mandatory fun, Now with oat milk. Dice: Otter's roll is **12**, your secret roll for Heron's DPO is **13**.



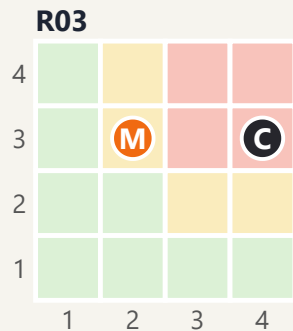
"Now each team gets its things." Two teams today: Otter and Heron.

Project 1: the start

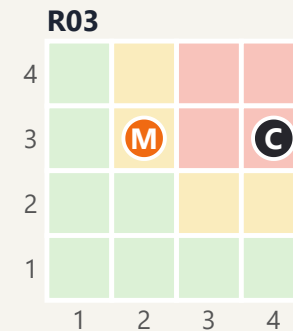


- Both teams get 10 coins: 30 each.
- The risk card lists, for each goal, **two numbers**: the **probability** (how likely) is the **row**, and the **impact** (how bad) is the **column**. Up and right is worse.
- **M** (orange): probability 3, impact 2 → the figure goes to **row 3, column 2**.
- **C** (black): probability 3, impact 4 → the figure goes to **row 3, column 4**.
- The red spaces (probability × impact above 8) are the ones to get out of. C is in the red now.
- No yellow card is on a table yet, so there are no yellow moves.

Otter: **30 coins**



Heron: **30 coins**



"New project. I pay each of you 10 coins." Turn over risk card R03 and tell the story: "Someone copied the live customer data into the test system, just to try something. Now twelve testers and a contractor can see everything."

Turn 1 • Team Otter plays a blue card

Rulebook 4.2: play a card (blue: face up and sideways); optional rule: explain it creatively

Team Otter’s hand

3 Ticket #4711

JUST-IN-TIME LOGGED ACCESS

-2 | 0 -1 | 0 +1 | 0

You introduce an access tool that gives the supplier's support a key for one ticket and a few hours. When the ticket closes, the key expires. Since the tool works for any supplier, you can **REUSE** it in every project now for 1 extra cost per project.

PLAYS

SDM SUPPLIER-2 - v0.8

1 Retention policy (on paper)

RETENTION SCHEDULE

-1 | 0

Write down how long each kind of data is kept.

Step 1: Write the policy. Step 2: Advise the policy. Step 3: There is no step 3.

SDM D1.7 - NIST SI-12 MIN RETAIN-1 - v0.8

2 Does it treat people alike?

BIAS AND ERROR TEST BEFORE LAUNCH

-1 | 0 -1 | 0

Before launch, test automated results for errors and for disadvantage to groups of people.

The model is 94% accurate. Nobody asked for whom.

SDM D1.2 - NIST SA-11 INF DECISION-1 - v0.8

2 Paper still works

DOCUMENTED MANUAL FALLBACK

0 | 1

Document a manual process that takes over during an outage, so people are not disadvantaged.

The binder with the procedure is stored in the system that is down.

SDM D1.4 - NIST CP-2 BCU FALLBACK-2 - v0.8

1 Ask for a human

HUMAN REVIEW ON REQUEST

0 | 1 0 | 1

A person decides again when someone contests an automated result.

The person is called Dave. Dave has 400 other coins.

SDM D1.5 INV HUMAN-1 - v0.8

2 Ask the people it affects

CONSULT AFFECTED PEOPLE EARLY

-2 | 0 -1 | 0

Involve the people affected, or their representatives, in the design.

They asked the one question nobody had thought of.

SDM D1.3 INV PEOPLE-1 - v0.8

2 Delete the export button

CLOSE UNUSED INTERFACES

-2 | 0 -1 | 0

Remove export functions and interfaces nobody needs.

Somebody needed it in 2019. Nobody remembers who.

SDM D1.6 NIST AC-4 UC-7 CSM INTERFACE-2 - v0.8

1 Just email us

SHARED MAILBOX, MANUAL LOOKUP

0 | 1

Offer one email address and look the person up in the systems by hand.

Works, as long as the one person who knows where to look is in today.

SDM D1.8 INV REQUEST-1 - v0.8

1 Only while it's needed

COLLECTION RULE PER PURPOSE

-1 | 0

Write down what may be collected for each purpose and for how long.

The rule is clear. Finding out who enforces it is the subject.

SDM D1.7 NIST PI-6 MIN WORKFLOW-1 - v0.8

The card it plays

3 Ticket #4711

JUST-IN-TIME LOGGED ACCESS

-2 | 0 -1 | 0 +1 | 0

You introduce an access tool that gives the supplier's support a key for one ticket and a few hours. When the ticket closes, the key expires. Since the tool works for any supplier, you can **REUSE** it in every project now for 1 extra cost per project.

Whoever waits for the approval will call this "friction".

SDM D1.3 - NIST AC-2(2), AU-2 CON-SUPPLIER-2 - v0.8

3 Ticket #4711

JUST-IN-TIME LOGGED ACCESS

-2 | 0 -1 | 0 +1 | 0

You introduce an access tool that gives the supplier's support a key for one ticket and a few hours. When the ticket closes, the key expires. Since the tool works for any supplier, you can **REUSE** it in every project now for 1 extra cost per project.

Whoever waits for the approval will call this "friction".

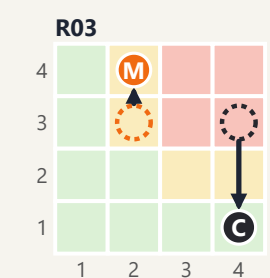
SDM D1.3 - NIST AC-2(2), AU-2 CON-SUPPLIER-2 - v0.8

Then: face up and sideways next to Team Otter.

- Pays 3 coins.
- Blue card: lay it **face up** and turn it **sideways** next to Otter. It is **still part of the hand**, and there is **no new card**. A blue card can be played **once per project**.
- Otter gets 1 coin for the explanation (1 or 2 coins for a good reason, nothing for a funny story that does not fit).

Circle	Left number: probability = the <u>rows</u>	Right number: impact = the <u>columns</u>
C -2 0	-2: 2 rows down : row 3 → row 1.	0 : no move, it stays in column 4.
T -1 0	No figure of this colour on the matrix: nothing moves.	
M +1 0	+1: 1 row up : row 3 → row 4.	0 : no move, it stays in column 2.

Otter: 30 → **28 coins**



Dashed ring: where the figure was. Arrow: the

“Turn one. Otter, your card?” Otter says in one sentence why it fits. A good reason earns **1 coin** (not a funny story). Read the circles aloud before anybody moves: **left number first** (probability, the rows), then the **right number** (impact, the columns). A **minus** goes down or left (good), a **plus** goes up or right (a downside).

Turn 1 · Team Heron plays a grey card

Rulebook 4.2: play a card (grey)

Team Heron's hand

3

Break glass in emergencies

APPROVAL FOR SENSITIVE RECORDS

-3|0

-1|0

+1|0

Require a second person's approval and a stated reason before anyone opens a sensitive record.

PLAYS

Friday afternoon.

SDM D1.3 · NIST AC-26, SC-12 CON-ACCESS-3 · v0.8

3

Locked at rest

AT-REST ENCRYPTION, MANAGED KEYS

0|+1

Encrypt disks and databases and manage the keys centrally. You go **GLOBAL** with the key service once, and from now on every project is covered.

Excellent protection against someone walking out with the disk.

SDM D1.3 · NIST SC-28, SC-12 CON-KHY-1 · v0.8

1

Names optional

REPORTS WITHOUT PERSONAL COLUMNS

-1|0

-1|0

Make reports and default views show no names or IDs unless someone needs them.

Funny how few people miss the name column.

SDM D1.7 · NIST AC-3 MIN-VIEW-1 · v0.8

1

Not in the test system

NO LIVE DATA IN TESTS

-1|0

-1|0

Never copy production personal data into test or training environments.

Famous last words: "It is only a copy!"

SDM D1.7 · NIST PM-25, SI-1020 MIN-TEST-1 · v0.8

1

Off until you say so

OPTIONAL FEATURES OFF BY DEFAULT

-2|0

-1|0

Optional features start switched off and need an active opt-in.

Marketing calls it "a missed opportunity". Everyone else calls it "the default".

SDM D1.2 · SI-17 · NIST SA-8 MIN-OPT-1 · v0.8

2

In plain words

EXPLAIN FACTORS IN PLAIN LANGUAGE

0|+2

0|+1

Explain in everyday language to the people affected which factors count.

Legal approved the wording. Nobody has read it since.

SDM D1.3 · SI-11 TRN-SCD-2 · v0.8

1

Find every copy

CROSS-SYSTEM CHECKLIST

0|+1

List every place where a person's data lives, and walk the list when someone asks.

The list is missing the shared drive. The shared drive knows.

SDM D1.6 MIN-ACCESS-1 · v0.8

3

Fix it once

CORRECTION LOOP WITH PROPAGATION

0|+2

0|+1

When a value is corrected at the source, make the fix reach every copy. Since the sync service works for any connected system, you can **REUSE** it in every project now for 2 extra cost per project.

There are four copies of that record. You have found three.

SDM D1.2 · NIST SI-1601, SI-1605 MIN-FIX-1 · v0.8

2

Signed, sealed, ignored

CONTRACT AND STATED REASON

-1|0

Bind supplier staff by contract to confidentiality and make them name a reason for every access. You go **GLOBAL** with the framework contract once, and from now on every supplier signs it.

A contract cannot stop anyone. It can only make them regret it.

SDM D1.3 · NIST PM-6, SA-9 CON-SUPP-2 · v0.8

The card it plays

3

Break glass in emergencies

APPROVAL FOR SENSITIVE RECORDS

-3|0

-1|0

+1|0

Require a second person's approval and a stated reason before anyone opens a sensitive record.

The emergency was, it turns out, a Friday afternoon.

SDM D1.3 · NIST AC-5, AC-2(2) CON-ACCESS-3 · v0.8

- Pays 3 coins.
- Grey card: to the **discard pile**, and Heron **draws a new card**: Answer, don't keep.

Circle	Left number: probability = the <u>rows</u>	Right number: impact = the <u>columns</u>
C -3 0	-3: 3 rows down : row 3 → row 1. It stops at the edge (1 or 4) and cannot go further.	0: no move, it stays in column 4.
T -1 0	No figure of this colour on the matrix: nothing moves.	
A +1 0	No figure of this colour on the matrix: nothing moves.	

Heron: 30 → 27 coins

R03

4

3

M

2

1

C

1

2

3

4

Dashed ring: where the figure was. Arrow: the move.

Drawn

3

Answer, don't keep

DON'T STORE IT

-2|-1

-1|0

-1|0

Check the answer once, for example "over 18", and store only the result, not the birth date it came from.

It cannot look what it never kept.

SDM D1.4, D1.7 · NIST SI-1811, SA-8 MIN-FIELDS-3 · v0.8

"Heron, your card."

Read the circles aloud before anybody moves: **left number first** (probability, the rows), then the **right number** (impact, the columns). A **minus** goes down or left (good), a **plus** goes up or right (a downside).

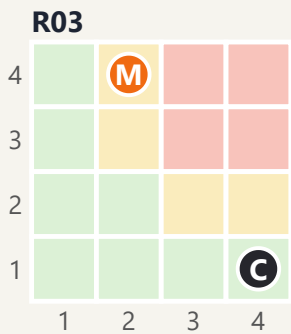
Event after turn 1

Rulebook 4.2: the facilitator draws an event card after every turn

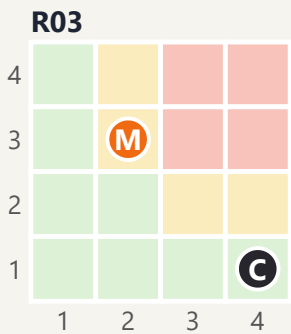


- **Everyone gains 2 coins.**
- Otter 30, Heron 29.
- No figure moves: this card is about coins only.

Otter: **30 coins**



Heron: **29 coins**



Draw the first event card and read it aloud. It affects all teams. After every turn the facilitator draws one.

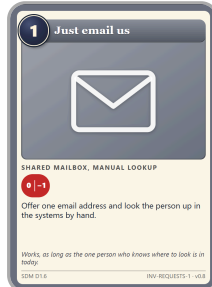
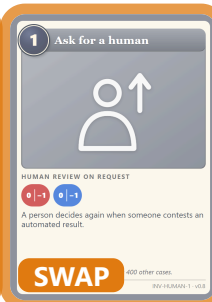
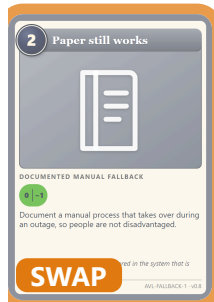
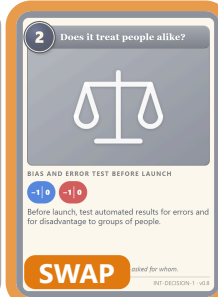
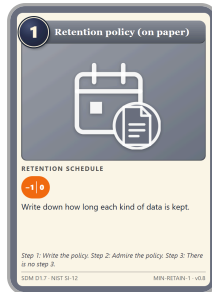
Turn 2 · Team Otter swaps cards

Rulebook 4.2: swap cards (free, and it is the action)

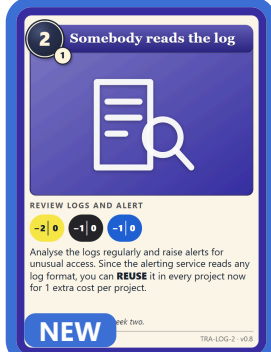
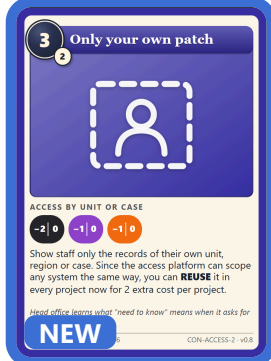
page 7

Team Otter's hand

SIDEWAYS

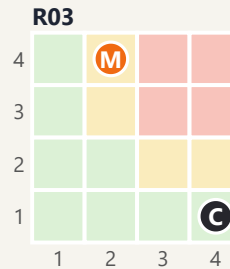


The new cards



- Swapping is **free** (up to 5 cards).
- Out: Does it treat people alike?, Paper still works, Ask for a human.
- In: Only your own patch, Somebody reads the log, Separate drawers.
- The blue card lies sideways: it is **not swapped**, it cannot be swapped until it is turned upright.
- No figure moves. The swap **is** the action: Otter plays no measure this turn, and still pays nothing.

Otter: 30 → **30 coins**



"Turn two. Otter, three of your cards do nothing for these figures. You can swap them: that is your whole action."

Turn 2 · Team Heron plays a yellow card

Rulebook 4.2: play a card (yellow: face up on the table, sideways)

Team Heron's hand

3 Locked at rest

AT-REST ENCRYPTION, MANAGED KEYS

0|-1

Encrypt disks and databases and manage the keys centrally. You go **GLOBAL** with the key service once, and from now on every project is covered.

PLAYS

SDM D1.3 · NIST SC-28, SC-12 CON-KEYS-1 · v0.8

1 Names optional

REPORTS WITHOUT PERSONAL COLUMNS

0|-1 0|-1 0

Make reports and default views show no names or IDs unless someone needs them.

Funny how few people miss the name column.

SDM D1.7 · NIST PM 25, SI 1020 MIN VIEW-1 · v0.8

1 Not in the test system

NO LIVE DATA IN TESTS

0|-1 0|-1 0

Never copy production personal data into test or training environments.

Famous last words: "It is only a copy!"

SDM D1.7 · NIST PM 25, SI 1020 MIN TEST-1 · v0.8

1 Off until you say so

OPTIONAL FEATURES OFF BY DEFAULT

0|-2 0|-1 0

Optional features start switched off and need an active opt-in.

Marketing calls it "a missed opportunity". Everyone else calls it "the default".

SDM D1.2 · B1.17 · NIST SA-6 MIN DEFAULT-1 · v0.4

2 In plain words

EXPLAIN FACTORS IN PLAIN LANGUAGE

0|-2 0|-1 0

Explain in everyday language to the people affected which factors count.

Legal approved the wording: Nobody has read it since.

SDM D1.5 · B1.1 TBA SCORE-1 · v0.4

1 Find every copy

CROSS-SYSTEM CHECKLIST

0|-1 0|-1 0

List every place where a person's data lives, and walk the list when someone asks.

The list is missing the shared drive. The shared drive knows.

SDM D1.6 WOV ALLDATA-1 · v0.8

3 Fix it once

CORRECTION LOOP WITH PROPAGATION

0|-2 0|-1 0

When a value is corrected at the source, make the fix reach every copy. Since the sync service works for any connected system, you can **REUSE** it in every project now for 2 extra cost per project.

There are four copies of that record. You have found three.

SDM D1.2 · NIST SI 1040, SI 1045 BCT REPEAT-2 · v0.4

2 Signed, sealed, ignored

CONTRACT AND STATED REASON

0|-1 0

Bind supplier staff by contract to confidentiality and make them name a reason for every access. You go **GLOBAL** with the framework contract once, and from now on every supplier signs it.

A contract cannot stop anyone. It can only make them regret it.

SDM D1.3 · NIST PM 25, SI 1020 CON SUPPLIER-1 · v0.8

3 Answer, don't keep

DON'T STORE IT

0|-2 0|-1 0 0|-1 0

Check the answer once, for example "over 18", and store only the result, not the birth date it came from.

It cannot last what it never kept.

SDM D1.4 · D1.17 · NIST SI 1040, SI 1045 MIN FIELDS-1 · v0.8

The card it plays

3 Locked at rest

AT-REST ENCRYPTION, MANAGED KEYS

0|-1

Encrypt disks and databases and manage the keys centrally. You go **GLOBAL** with the key service once, and from now on every project is covered.

Excellent protection against someone walking out with the disk.

SDM D1.3 · NIST SC-28, SC-12 CON-KEYS-1 · v0.8

3 Locked at rest

AT-REST ENCRYPTION, MANAGED KEYS

0|-1

Encrypt disks and databases and manage the keys centrally. You go **GLOBAL** with the key service once, and from now on every project is covered.

Excellent protection against someone walking out with the disk.

SDM D1.3 · NIST SC-28, SC-12 CON-KEYS-1 · v0.8

- Pays 3 coins.
- Yellow card: **face up on the table** and turned **sideways**: sideways means its moves are made in this project. Its moves are made now. It stays on the table.
- Heron draws a new card: Who covers on Friday?.

Circle	Left number: probability = the <u>rows</u>	Right number: impact = the <u>columns</u>
C 0 -1	0 : no move, it stays in row 1.	-1 : 1 column left : column 4 → column 3.

Heron: 29 → **26 coins**

R03

4				
3		M		
2				
1			C	
	1	2	3	4

Dashed ring: where the figure was. Arrow: the move.

Drawn

2 Who covers on Friday?

DEPUTIES FOR KEY ROLES

0|-2 0

Name a substitute for every key role. You go **GLOBAL** with the roster once, and from now on every project has one.

The substitute is on holiday too. It was in the plan.

SDM D1.1 JNL DEPUTY-1 · v0.8

Then: face up and sideways on the table.

“Heron, you play a yellow card. It stays on the table, and from now on it works in every project.”

Read the circles aloud before anybody moves: **left number first** (probability, the rows), then the **right number** (impact, the columns). A **minus** goes down or left (good), a **plus** goes up or right (a downside).

Event after turn 2

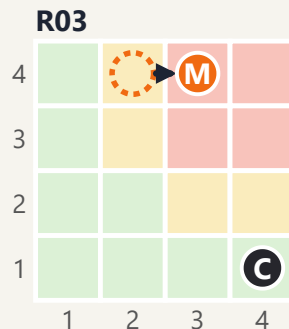
Rulebook 4.2: events change figures; figures stay between 1 and 4

page 9



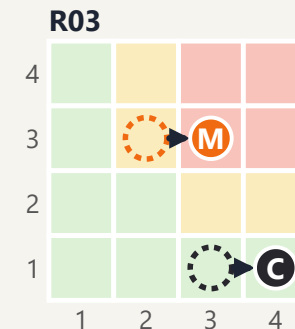
- **Every figure goes one column to the right:** impact +1 for every goal, on every matrix. Impact is the **column**, so figures move sideways, not up or down.
- Otter, M: column 2 → column 3 (the row stays 4).
- Otter, C: already in column 4, so it **stays**.
- Heron, M: column 2 → column 3 (the row stays 3).
- Heron, C: column 3 → column 4 (the row stays 1).
- This is the only kind of move that is bad for everybody: check both matrices together.

Otter: **30 coins**



Dashed ring: where the figure was. Arrow: the move.

Heron: **26 coins**



Dashed ring: where the figure was. Arrow: the move.

Draw the second event card and read it aloud. It affects all teams.

Turns 3 and 4 (skipped for the demo)

Rulebook 4.2: four turns, an event after each

Mandatory fun

ALL-HANDS

Nothing happens. The meeting lasts all afternoon, but it decides nothing that touches your project.

The slides had 61 pages. Slide 4 was about you.

EV01 - v0.8

Now with oat milk

NEW COFFEE MACHINE

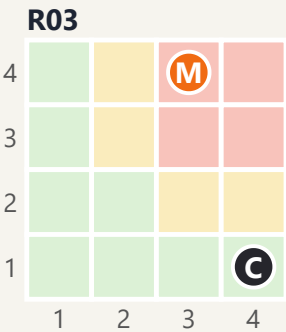
Nothing happens. A better coffee machine does not change a single risk or measure.

Productivity is unchanged. Morale is up 3 percent, according to a survey about the machine.

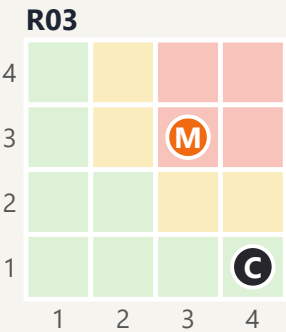
EV02 - v0.8

- Draw and read the next two events: **nothing happens** in both.
- Both teams keep their cards and coins. In a real game each team would play or swap again.

Otter: **30 coins**



Heron: **26 coins**



“In a real game you do this two more times. For today we skip them: both teams do nothing.”

End of project 1 · Before the dice: Heron calls in the DPO

Rulebook 4.3 optional rule: call in the DPO, before the roll (only for a high risk)

page 11

- Heron pays 1 coin (not refunded): 26 → 25.
- The project moves to the next round: Heron keeps its matrix and figures, and gets a full set of turns again.
- Heron has **no roll and no check** this time: no bill for this round.
- Blue and yellow cards stay as they are for now: they are turned upright at the **start of the next project**, also after a bought DPO.
- R03 is now a **moved project**: blue and yellow cards are not played on it any more. Only grey cards move its figures.

Heron: 26 → **25 coins**



"The project is over. **Before anybody rolls**: does a team want to call in the DPO?" Heron's M stands at probability 3, impact 3 (row 3, column 3): that is a red space, a high risk. Heron may call in the DPO for **1 coin**.

"Heron, give me one reason management should stop this project." Let Heron name a real weakness.

Roll your own d20 **in secret**. Script: **13**. Ten or above: management is open to it. Say: "Management buys it."

End of project 1 · Otter rolls and pays

SIDEWAYS

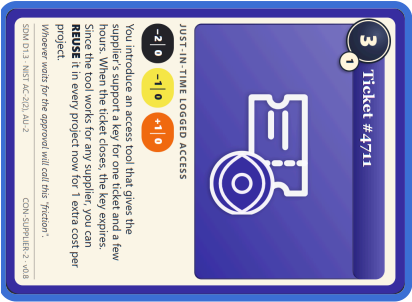
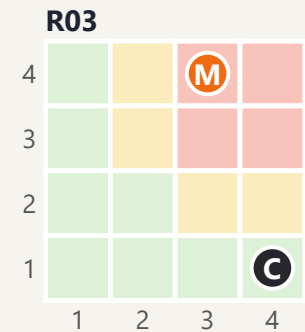


Figure	Probability	Needs	Roll	Result	Cost (impact×impact)
M	4	20	12	FAILS	3×3 = 9
C	1	2	12	safe	–

- **M** fails and stands in column 3 (impact 3): the cost is impact × impact = 3×3 = **9 coins**. Story: an inquiry by the authority.
- Otter pays 9: 30 → 21.
- The blue card stays **sideways** for now. It is turned upright at the start of the next project.

Otter: 30 → **21 coins**

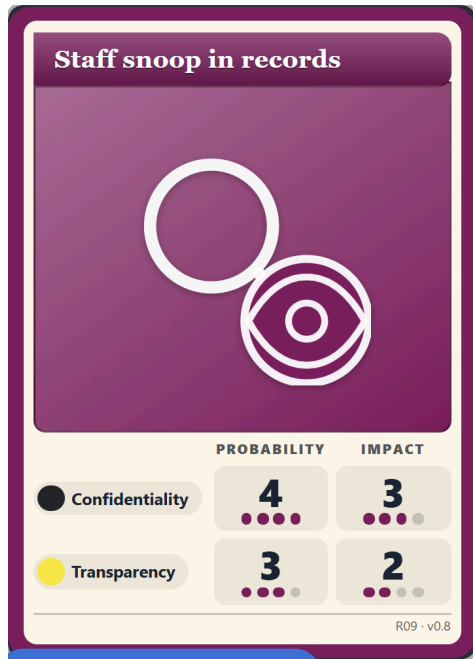


“Now the dice. Otter, roll your d20 in the open.” Script: Otter rolls **12**. (Heron has no roll: its DPO was bought.) Use the table of the facilitator sheet: the **row** (probability) says which roll is needed, the **column** (impact) says what a failure costs.

Project 2: the start

Rulebook 4.1: start of a project; blue and yellow cards turned upright, upright yellow cards make their moves, then lie sideways

page 13



- Both teams get 10 coins: Otter 31, Heron 35.
- Otter **turns the blue card upright**. It stays **face up**: a face-up card was played before, so playing it again costs only the small number.
- New matrix, figures on the starting spaces: **C**: probability 4, impact 3 → **row 4, column 3**; **T** (yellow): probability 3, impact 2 → **row 3, column 2**.
- Heron's yellow card (Locked at rest) **stands upright**: its moves are still to make. Heron makes them on the new matrix: its circle is 0 | -1, so C goes **one column left**: column 3 → column 2 (the arrow).
- Heron's old matrix R03 is a project that was moved by the DPO: **yellow and blue cards are not played on it**, so it gets no yellow move now.
- Then Heron **turns the yellow card sideways**: its moves are made in this project.

Otter: **31 coins**

	R09			
4			C	
3		T		
2				
1				

Heron: **35 coins**

	R03			
4				
3			M	
2				
1				C

	R09			
4		C		
3		T		
2				
1				

“New project. 10 coins each.” Deal up: check that each team holds 9 cards, the blue card on the table included. Both teams **turn their blue and yellow cards upright**.

Risks: with the optional rule (1, 2, 2, 3 risk cards, then repeat) project 2 would have two. For beginners it is better to keep the number lower, so we turn over only R09: “Two colleagues were caught reading the records of a well-known customer, out of curiosity.”

Project 2, turn 1 · Otter plays its blue card again

Rulebook 4.2: a blue card costs less when played again

Team Otter's hand

3

Ticket #4711

JUST-IN-TIME LOGGED ACCESS

-2 | 0 -1 | 0 +1 | 0

PLAYS

You introduce an access tool that gives the supplier's support a key for one ticket and a few hours. When the ticket closes, the key expires. Since the tool works for any supplier, you can REUSE it in every project now for 1 extra cost per project.

SDM D1.3 - NIST AC-2(2), AU-2 CON-SUPPLIER-2 - v0.8

2

Delete the export button

CLOSE UNUSED INTERFACES

-2 | 0 -1 | 0

Remove export functions and interfaces nobody needs.

Somebody needed it in 2019. Nobody remembers who. SDM D1.4 - NIST AC-4, SC-7 LHM-UIABUS-2 - v0.4

3

Only your own patch

ACCESS BY UNIT OR CASE

-2 | 0 -1 | 0 -1 | 0

Show staff only the records of their own unit, region or case. Since the access platform can scope any system the same way, you can REUSE it in every project now for 2 extra cost per project.

Head office learns what "need to know" means when it asks for a country-wide report. SDM D1.3 - NIST AC-5, AC-10 CON-ACCESS-2 - v0.4

1

Retention policy (on paper)

RETENTION SCHEDULE

-1 | 0

Write down how long each kind of data is kept.

Step 1: Write the policy. Step 2: Advise the policy. Step 3: There is no step 3. SDM D1.7 - NIST SI-12 MIN-RETAIN-1 - v0.4

1

Just email us

SHARED MAILBOX, MANUAL LOOKUP

0 | -1

Offer one email address and look the person up in the systems by hand.

Works, as long as the one person who knows where to look is in the job. SDM D1.6 INV-REQUESTS-1 - v0.4

2

Somebody reads the log

REVIEW LOGS AND ALERT

-2 | 0 -1 | 0 -1 | 0

Analyse the logs regularly and raise alerts for unusual access. Since the alerting service reads any log format, you can REUSE it in every project now for 1 extra cost per project.

Alert fatigue arrives in week two. SDM D1.5 - NIST AU-6, SI-4 TNA-LOGS-2 - v0.4

2

Ask the people it affects

CONSULT AFFECTED PEOPLE EARLY

-2 | 0 -1 | 0

Involve the people affected, or their representatives, in the design.

They asked the one question nobody had thought of. SDM AG-3(2) TRA-VOICE-1 - v0.4

1

Only while it's needed

COLLECTION RULE PER PURPOSE

-1 | 0

Write down what may be collected for each purpose and for how long.

The rule is clear. Finding out who enforces it is the sequel. SDM D1.7 - NIST PT-3 MIN-WAREHOUSE-1 - v0.4

3

Separate drawers

SEPARATE STORES PER PURPOSE

-2 | 0 -1 | 0

Keep data for different purposes in separate stores with separate access paths.

It was one big table because that was easier. It was always going to be easier. SDM D1.4 - Bayesian 10 NIST AC-4 LHM-FUNCTION-2 - v0.4

The card it plays

3

Ticket #4711

JUST-IN-TIME LOGGED ACCESS

-2 | 0 -1 | 0 +1 | 0

You introduce an access tool that gives the supplier's support a key for one ticket and a few hours. When the ticket closes, the key expires. Since the tool works for any supplier, you can REUSE it in every project now for 1 extra cost per project.

Whoever waits for the approval will call this "friction".

SDM D1.3 - NIST AC-2(2), AU-2 CON-SUPPLIER-2 - v0.8

3

Ticket #4711

JUST-IN-TIME LOGGED ACCESS

-2 | 0 -1 | 0 +1 | 0

You introduce an access tool that gives the supplier's support a key for one ticket and a few hours. When the ticket closes, the key expires. Since the tool works for any supplier, you can REUSE it in every project now for 1 extra cost per project.

Whoever waits for the approval will call this "friction".

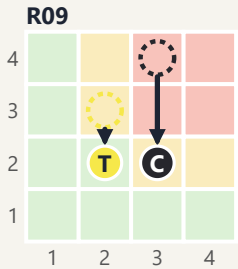
SDM D1.3 - NIST AC-2(2), AU-2 CON-SUPPLIER-2 - v0.8

Then: face up and sideways next to Team Otter.

- Pays only 1 coin (the small number), not 3: the card is face up, so it was played before.
- Blue card: **face up and sideways** next to Otter again, still part of the hand, no new card.

Circle	Left number: probability = the rows	Right number: impact = the columns
C -2 0	-2: 2 rows down : row 4 → row 2.	0: no move, it stays in column 3.
T -1 0	-1: 1 row down : row 3 → row 2.	0: no move, it stays in column 2.
M +1 0	No figure of this colour on the matrix: nothing moves.	

Otter: 31 → 30 coins



Dashed ring: where the figure was. Arrow: the move.

“Otter, your blue card was turned upright at the end of the last project. It is face up, so it was played before: look at the small number on it, that is the price now.”

Read the circles aloud before anybody moves: **left number first** (probability, the rows), then the **right number** (impact, the columns). A **minus** goes down or left (good), a **plus** goes up or right (a downside).

Project 2, turn 1 · Heron: one card, two matrices

Rulebook 4.2: a card moves every matrix that has a figure of that colour

Team Heron's hand

1 Names optional

REPORTS WITHOUT PERSONAL COLUMNS

-1

0

-1

0

Make reports and default views show no names or IDs unless someone needs them.

PLAYS

SDM D1.7 · NIST PA-25, SI-132D MIN-VIEW-1 · v0.4

2 In plain words

EXPLAIN FACTORS IN PLAIN LANGUAGE

0

-2

0

-1

Explain in everyday language to the people affected which factors count.

Legal approved the wording. Nobody has read it since.

SDM D1.5, B1.1 TBA SCORP-2 · v0.4

2 Signed, sealed, ignored

CONTRACT AND STATED REASON

0

-1

0

0

Bind supplier staff by contract to confidentiality and make them name a reason for every access. You go **GLOBAL** with the framework contract once, and from now on every supplier signs it.

A contract cannot stop anyone. It can only make them regret it.

SDM D1.3 · NIST PS 4, SA-9 SDM SCORP-1 · v0.4

1 Not in the test system

NO LIVE DATA IN TESTS

-1

0

-1

0

Never copy production personal data into test or training environments.

Famous last words: "It is only a copy!"

SDM D1.7 · NIST PA-25, SI-132D MIN-VIEW-1 · v0.4

1 Find every copy

CROSS-SYSTEM CHECKLIST

0

-1

0

0

List every place where a person's data lives, and walk the list when someone asks.

The list is missing the shared drive. The shared drive knows.

SDM D1.6 MIN-ALLOCATION-1 · v0.4

3 Answer, don't keep

DON'T STORE IT

-2

-1

-1

0

Check the answer once, for example "over 18", and store only the result, not the birth date it came from.

It cannot leak what it never kept.

SDM D1.4, D1.7 · NIST SI-132D, SA-9 MIN-PRIVACY-1 · v0.4

1 Off until you say so

OPTIONAL FEATURES OFF BY DEFAULT

-2

0

-1

0

Optional features start switched off and need an active opt-in.

Marketing calls it "a missed opportunity". Everyone else calls it "the default!"

SDM D1.2 · NIST SA-9 MIN-DEFAULT-1 · v0.4

3 Fix it once

CORRECTION LOOP WITH PROPAGATION

0

-2

0

-1

When a value is corrected at the source, make the fix reach every copy. Since the sync service works for any connected system, you can **REUSE** it in every project now for 2 extra cost per project.

There are four copies of that record. You have found three.

SDM D1.2 · NIST SI-132D, SI-132D MIN-REPAIR-1 · v0.4

2 Who covers on Friday?

DEPUTIES FOR KEY ROLES

0

-2

0

0

Name a substitute for every key role. You go **GLOBAL** with the roster once, and from now on every project has one.

The substitute is on holiday too. It was in the plan.

SDM D1.1 MIN-DEPUTY-1 · v0.4

The card it plays

1 Names optional

REPORTS WITHOUT PERSONAL COLUMNS

-1

0

-1

0

Make reports and default views show no names or IDs unless someone needs them.

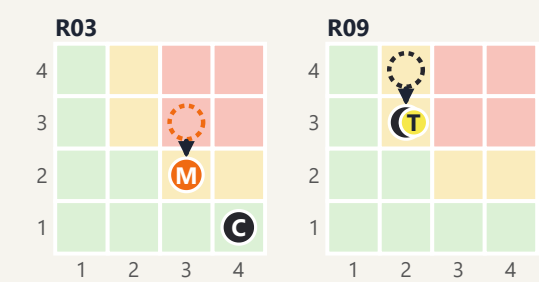
Funny how few people miss the name column.

SDM D1.7 · NIST AC-3 MIN-VIEW-1 · v0.8

- Pays 1 coin.
- Grey card to the discard; Heron draws Names stay in the vault.
- A grey card moves **every matrix**, also R03. Blue and yellow cards would not (R03 is moved).

Circle	Left number: probability = the <u>rows</u>	Right number: impact = the <u>columns</u>
M -1 0	-1: 1 row down : row 3 → row 2.	0: no move, it stays in column 3.
C -1 0	R03 -1: 1 row down : row 1 → row 1. It is already at the edge and stays. R09 -1: 1 row down : row 4 → row 3.	R03 0: no move, it stays in column 4. R09 0: no move, it stays in column 2.

Heron: 35 → 34 coins



Dashed ring: where the figure was. Arrow: the move.

Drawn

3 Names stay in the vault

PSEUDONYMISE, KEY HELD SEPARATELY

0

-1

0

-1

You introduce a pseudonymisation service; names go in, tokens come out, the key stays in the vault. Since the vault knows nothing about your data model, you can **REUSE** it in every project now for 1 extra cost per project.

The vault password is, hopefully, not on a sticky note.

SDM D1.4 · NIST SI-132D, SC-12 LINK-ID-1 · v0.8

“Heron, your card works on both of your matrices.” Let Heron move the figures one matrix at a time. Read the circles aloud before anybody moves: **left number first** (probability, the rows), then the **right number** (impact, the columns). A **minus** goes down or left (good), a **plus** goes up or right (a downside).

What if...

Side steps for the same moments

page 16

Otter cannot pay. The bill is 9 coins, but Otter has only 6. A team that cannot pay is **out of business**. Optional rule: Otter argues it was not its fault; if you are convinced you cover some of the fee, for example half (5 coins): Otter pays 4, stays in and has 2 coins left. Cover none of it if the measures were scattered. Roll your own d20 in secret as a guide: 10 or above means management is open to it, and a good argument beats a low roll.

Heron's DPO is refused. With a secret roll below 10 and a weak argument, management does not buy it. Heron has paid the coin and goes on with its roll like any team.

A team cannot pay for a card. It picks a cheaper card or swaps.

A figure would leave the matrix. It stops at 1 or at 4. A plus on a figure at 4 does nothing.

Other event cards

One action is one turn of a team

page 17

Card	What you do on paper
Coins: EV05, EV06, EV07 (gain); EV08, EV09, EV10 (lose)	Every team gains or loses the coins now. A team with fewer pays what it has.
Lose an action: EV11, EV15, EV30 (1), EV29 (2)	Every team has that many actions fewer in this project, if it still has them. Say the new number of turns.
Gain an action: EV27, EV28	One more turn for every team in this project.
Trap: EV21 to EV26	It takes one action from every team and does nothing for the people in the data.
Budget freeze: EV12	Each team's next measure may cost at most 10 percent of its coins, and at least 1.
Dares: EV13, EV14, EV16, EV31 to EV37	The team does what it says until it plays its next card.
Better: EV19	Pick one risk of the project at random. On each matrix the figure with the highest score goes down one row.

Other event cards

One action is one turn of a team

page 18

Card	What you do on paper
Disable the last card: EV20	The last card each team played does nothing for the rest of the project: move its figures back. The card stays.
Wing it: EV38	Each team plays three cards from its hand, taken blind, in order, paying as usual; the blue cards lying sideways are not taken. It is free play: no turns are used. A team that cannot pay ends its project now.
Reset: EV39	Every card played in this project is gone (to the discard), and so are all yellow cards on the table. Figures go back to their starting spaces. The coins stay spent.
New goal: EV40, EV41	Pick one risk of the project at random. Every team puts the first goal, in the order of the letters A, C, I, L, M, T, V, that is not on that matrix yet, on probability 3, impact 3. Cards played before do not move it; later cards do.
End the project now: EV17	Every team stops its turns and goes to the end of the project. A team may still call in the DPO first, then everybody rolls, checks and pays.
Nothing happens: EV01 to EV04	Read it and say "nothing happens".

Feature checklist

Every rule is shown once

page 19

Rule or feature	Shown on
Set up the table: piles, matrices, figures; coins, hand, dice and player aid for each team	page 1, page 2
Pay at the start of a project	page 3, page 13
Reveal a risk, tell the story, place the figures	page 3, page 13
Play a blue (shareable) card: face up and sideways next to the team, still part of the hand, no new card, once per project	page 4
Play a grey (project) card: discard, draw a new card	page 5
Read the circles: left probability (rows), right impact (columns); minus down or left, plus up or right	page 4
A figure stops at the edge (1 and 4)	page 5, page 9
A circle of a colour that is not on the matrix does nothing	page 4
Optional: a good explanation earns a coin	page 4
The facilitator draws an event after every turn	page 6, page 9, page 10

Feature checklist

Every rule is shown once

page 20

Rule or feature	Shown on
Swap cards: free, it is the action; a blue card lying sideways cannot be swapped	page 7
Play a yellow (central) card: face up on the table, moves now, turned sideways, draw a new card	page 8
Roll, check each figure, pay impact times impact	page 12
Optional: the DPO is called before the dice; no roll, no check; the round still ends and the project goes on	page 11
Blue and yellow cards are not played on a project that was moved by the DPO; only grey cards move its figures	page 13, page 15
Turn blue and yellow cards upright at the start of a project, also after a bought DPO; an upright yellow card makes its moves once on the new matrix, then lies sideways	page 13
A blue card costs less when played again (face up = played before), and lies sideways again	page 14
One card moves every matrix with that colour	page 15
A team that cannot pay is out; optional fee relief	What if
Other events	Other event cards